

Ingeniería de Software 3

Práctica 3 - Auditoría

Parte I - Conceptos generales	2
Parte II - Controles y riesgos de Auditoría	7
Parte III - Proceso de Auditoría	8
Parte IV - Gobernanza de TI	8

Parte I - Conceptos generales

1. Explique las razones principales para auditar sistemas y dar ejemplos de cada una

Razones para auditar:

- Costos por pérdida de datos:
 - Ejemplo: pérdida de cuentas corrientes, pérdida de los datos de los alumnos
 - Ejemplo: Un fallo en el sistema de base de datos de facturación de un retailer provoca la corrupción de las ventas de última semana. Recuperar y reconstruir esas transacciones exige horas de trabajo manual y reclamos de clientes, generando pérdidas por ventas no registradas y penalizaciones contractuales
- Costos por toma de decisiones incorrectas
 - Una regla de decisión incorrecta puede tener un impacto menor. Ejemplo: cálculo de amortización erróneo en un bien de poco valor
 - En otras, el impacto puede ser considerable. ¿Por ejemplo? Robo de datos del ReNaPer
 - Ejemplo: Un dashboard de indicadores financieros arroja valores erróneos en el margen de ganancia debido a una fórmula mal parametrizada. La gerencia, confiando en esos datos, recorta el presupuesto de marketing y provoca una caída significativa en la captación de nuevos clientes
- Costos por abusos computacionales:
 - Tipos de abusos:
 1. Hacking
 2. Virus
 3. Acceso físico ilegal:
 - Ejemplo: a una sala de cómputos o a una terminal
 4. Abuso de privilegios
 - Ejemplo: hacen copias no autorizadas de los datos a los cuales se les otorgó acceso
- Costos por errores de computación:
 - Ejemplo: Therac 25
 - Ejemplo: Un error en el algoritmo de un sistema de control de temperatura en una planta de alimentos hace que los hornos funcionen a 20 °C más de lo debido. Se queman lotes completos y se detiene la línea de producción para limpieza y recalibración, generando desperdicio y horas muertas de planta
- Valor de hardware, software y personal:
 - Recursos críticos en las organizaciones:
 1. Datos: ¿qué pasa si la competencia obtiene información confidencial?

2. Hardware: ¿qué pasa si un componente crítico deja de funcionar?
 3. Software: ¿qué pasa si se destruye?
 4. Personal: ¿qué pasa si un profesional calificado deja la empresa?
 - Ejemplo: Se adquiere un nuevo ERP de alto costo pero, tras instalarlo, nunca se configura correctamente y permanece infrautilizado. Auditar permite identificar licencias sin uso, servidores dedicados ociosos y roles de administración duplicados, recuperando inversión al reasignar o decomisionar recursos
 - Evolución controlada de TI:
 - Se argumenta que la confiabilidad de los sistemas computarizados complejos no está garantizada
 - Las consecuencias de usar sistemas no confiables puede ser catastrófica
 - Ejemplo: Sin una auditoría, las actualizaciones de sistema se despliegan de manera desordenada: unas máquinas se quedan en versiones antiguas y otras en la última, causando incompatibilidades. La auditoría revela la falta de un plan de gestión de cambios y establece un proceso formal que coordina parches, pruebas y despliegues
 - Mantenimiento de privacidad:
 - Ejemplo: Un sistema CRM almacena datos de clientes en texto plano y los replica en copias de seguridad sin cifrar. Auditorías regulares identifican este riesgo y llevan a implementar cifrado en reposo y en tránsito, así como políticas de acceso basadas en roles, evitando fugas de información personal
2. *Para cada uno de los siguientes interesados, presente un ejemplo de cómo un mal procesamiento de información realizado por un sistema informático, puede conducir a una toma de decisiones incorrecta:*
- *Gerente de una empresa vinculada a la industria automotriz.*

Escenario de mal procesamiento: El sistema de gestión de inventarios arroja un nivel de stock de componentes críticos (p. ej. airbags) por encima del real debido a un fallo en la conciliación entre almacenes

Decisión incorrecta: El gerente, confiando en esos datos, decide posponer un nuevo pedido de suministro y redirigir presupuesto a otras áreas. Como resultado, cuando arranca la próxima línea de producción, faltan airbags y se detiene la planta, generando paradas de máquina, penalidades por retrasos y demora en entregas
 - *Funcionario de ARBA.*

Escenario de mal procesamiento: El sistema de recaudación y análisis de bases imponibles procesa erróneamente la declaración de ingresos de una firma, duplicando el importe declarado en su base de datos por un error de redondeo

Decisión incorrecta: El funcionario emite una liquidación de impuestos con un monto muy superior al real. Esto provoca que la empresa recurra la fiscalización, retrase pagos, incurra en cargos por mora y desvíe recursos legales para revertir un cobro indebido

- *Consejo Directivo de una facultad.*

Escenario de mal procesamiento: El sistema de seguimiento de matrícula y rendimiento académico calcula mal las tasas de deserción por carrera, omitiendo a estudiantes que cambiaron de especialidad

Decisión incorrecta: Creyendo que cierta carrera tiene una deserción muy alta, el Consejo decide recortar cupos y recursos docentes para esa unidad académica. En realidad, la demanda era estable y la “falsa” deserción provenía de traslados internos. La medida deja plazas vacías y desincentiva la inscripción de nuevos alumnos, afectando la viabilidad financiera de la facultad

3. *¿Qué tipo de abusos computacionales conoce? ¿Cuáles son las consecuencias de estos abusos?*

Tipos de abusos:

1. Hacking:

- Consecuencias

- Pérdida o filtración de datos sensibles (clientes, finanzas, propiedad intelectual)
- Interrupción del servicio (denegación de servicio, ransomware)
- Daño reputacional ante clientes y socios
- Sanciones legales por incumplimiento de regulaciones (protección de datos, financiera)

2. Virus:

- Consecuencias:

- Corrupción o encriptación de archivos → pérdida de información crítica
- Propagación a otros equipos → afectación masiva
- Ransomware: secuestro de datos y exigencia de rescate
- Impacto en el rendimiento del sistema y aumento de costos de limpieza y restauración

3. Acceso físico ilegal:

- Como resultado, pueden causar daño físico al hardware o hacer copias no autorizadas de programas y datos

- Consecuencias:

- Robo de hardware o dispositivos extraíbles (laptops, discos duros, USB)
- Instalación de malware “in situ” o captura de credenciales (teclado, cámara oculta)
- Sabotaje físico (desconexión de cables, daño de componentes) → paradas no planificadas

- Violación de perímetros de seguridad y necesidad de inversión en controles de acceso físico
- 4. Abuso de privilegios:
 - Consecuencias:
 - Modificación o eliminación de datos críticos sin autorización
 - Instalación de puertas traseras o cuentas “fantasma” para acceso futuro
 - Erosión de la confianza interna y ruptura de controles de segregación de funciones
 - Riesgo de fraude y posibles responsabilidades legales para la organización

4. *Explique al menos dos características que diferencien entre un abuso informático y otro tipo de fraude comercial.*

1. Medio utilizado: tecnológico vs. manual o administrativo:

- Abuso informático:
 - Se comete utilizando sistemas computacionales, redes, software o accesos digitales
 - Ejemplo: manipular una base de datos para alterar registros de facturación
- Fraude comercial:
 - Suele realizarse mediante documentos físicos, engaños verbales o transacciones fuera del entorno digital
 - Ejemplo: falsificar una factura en papel o entregar productos de menor calidad a lo pactado

2. Rastro y visibilidad del acto

- Abuso informático: puede dejar rastros complejos y difíciles de detectar si no hay monitoreo adecuado (logs, actividad en segundo plano, cambios en bases de datos). A veces los actos se automatizan y escalan rápidamente sin intervención humana directa
- Fraude comercial: generalmente deja evidencias físicas o administrativas más visibles (firmas falsas, diferencias contables, testigos), y el fraude suele ser más fácil de detectar mediante controles contables tradicionales

5. *Describa con sus palabras qué entiende por auditoría de sistemas de información.*

La auditoría de sistemas de información es el proceso de recolectar y evaluar evidencia para determinar si:

1. El sistema automático preserva los activos
2. Mantiene la integridad de los datos
3. Permite que los objetivos organizacionales se alcancen con eficacia
4. Usa los recursos con eficiencia

Muchas veces la auditoría tiene otro propósito: asegurar que la organización cumple con determinadas regulaciones, reglas y condiciones, ya sea voluntaria o involuntariamente

Ejemplos:

- Entidades financieras
- Normas ISO

6. *Explique los cuatro objetivos de la auditoría de sistemas de información.*

1. Mejorar la salvaguarda de activos:

- Los activos de los SI incluyen:
 - Hardware
 - Software
 - Facilidades
 - Personas (conocimientos)
 - Archivos de datos
 - Documentación de sistemas
 - Insumos

2. Mejorar la integridad de los datos:

- Es un estado en el cuál los datos poseen ciertos atributos:
 - Completitud
 - Consistencia
 - Veracidad
 - Correctitud
- Si la integridad de los datos de una organización no es mantenida, no posee representación de sí misma o de los eventos
- Sin integridad de datos se pueden producir pérdidas de ventajas competitivas

3. Mejorar la efectividad de los sistemas:

- Un sistema de información es efectivo si satisface sus objetivos
- Formas de evaluar la efectividad de los sistemas:
 - Durante el proceso de desarrollo para garantizar que se satisfacen los requerimientos de los usuarios
 - Mediante una post-auditoría
- Para poder evaluar la efectividad de un sistema de información se deben conocer:
 - Las características de los usuarios
 - El entorno de toma de decisiones

4. Mejorar la eficiencia de los sistemas:

- Un SI es eficiente si usa los recursos mínimos para satisfacer sus objetivos
- Recursos de un sistema de información:
 - Tiempo de procesador
 - Periféricos
 - Software
 - Trabajo manual
- Muchas veces el uso de los recursos no se puede estudiar con respecto a un sólo sistema
- Generalmente, la eficiencia se estudia cuando se agotan los recursos

7. *¿Qué significa que la alta gerencia implemente un sistema de control interno? ¿Cómo se lleva a cabo?*

Que la alta gerencia implemente un sistema de control interno significa que se hace responsable de diseñar, aprobar y mantener todo el conjunto de políticas, procesos, estructuras y recursos necesarios para garantizar que existan:

- Separación de obligaciones
- Delegación clara de autoridad y responsabilidades
- Reclutamiento y entrenamiento de personal calificado
- Sistema de autorizaciones
- Documentos y registros adecuados
- Control físico y documentación sobre los activos
- Chequeos independientes de performance
- Comparación periódica de activos con registros contabilizados

Parte II - *Controles y riesgos de Auditoría*

8. *Explique por qué un control en un sistema de información es un sistema.*

Un control en un sistema de información deja de ser una acción aislada (por ejemplo, “poner una contraseña”) y se concibe como un sistema porque reúne las siguientes características de todo sistema formal:

- Conjunto de elementos interrelacionados:
 - Incluye políticas, procedimientos, herramientas y responsables
 - Por ejemplo, en el control de acceso por password participan:
 - Un módulo de generación de contraseñas (reglas de complejidad)
 - Un servicio de autenticación (validación de usuario/clave)
 - Un almacén seguro de credenciales (cifrado, hashing)
 - Un mecanismo de bloqueo ante intentos fallidos
 - Registros de auditoría (logs) que documentan accesos y rechazos
- Propósito u objetivo:
 - Como cualquier sistema, el control busca un fin claro: prevenir accesos no autorizados, detectar usos indebidos o permitir la recuperación tras un incidente
 - Sin un objetivo definido, no habría modo de medir su eficacia ni su necesidad
- Procesos de entrada-proceso-salida:
 - Entrada: datos o acciones de usuarios (por ejemplo, nombre de usuario y contraseña)
 - Proceso: validación, comparación con la base de datos de credenciales, aplicación de reglas de bloqueo
 - Salida: permiso o denegación de acceso, generación de un evento de alarma, registro en log
- Retroalimentación y mejora continua:
 - Los controles incorporan mecanismos de monitoreo (logs, alertas, métricas de intento de acceso)

- Sobre esa información, se ajustan políticas (p. ej. aumentar la complejidad mínima de passwords, cambiar intervalos de caducidad, endurecer los bloqueos) para corregir fallos detectados
- Dependencia de un entorno:
 - Un control opera siempre dentro de un contexto:
 - Requisitos de negocio (cuáles sistemas proteger)
 - Regulaciones legales (frecuencia de rotación de claves, estándares de cifrado)
 - Infraestructura tecnológica (servidores de autenticación, redes, directorios)
 - Esa interacción con el entorno (y otros controles) lo convierte en un subsistema más del sistema de información global

En resumen, llamar “control” a una simple regla sin estructura oculta su verdadera naturaleza: solo al integrarlo con políticas, tecnologías, procedimientos de monitoreo y roles responsables conforma un sistema completo que tiene la capacidad no solo de prevenir eventos ilegales, sino también de detectar, reportar y corregir las desviaciones

9. *Explique las diferencias entre un control preventivo, control detectivo, y control correctivo. Provea ejemplos para cada tipo de control.*

Tipos de controles:

- Control Preventivo:
 - Instrucciones de cómo completar un formulario (las instrucciones no son el control)
 - Ejemplo: instrucciones en un formulario que indican “Ingrese DNI sin puntos y sin espacios”
- Control Detectivo:
 - Un programa que valida datos de input, rechazando los erróneos
 - Ejemplo:
 - Programa de validación de inputs que revisa cada campo al enviarlo y rechaza:
 - Un e-mail sin “@”
 - Una fecha fuera de rango (31/02/2025)
 - Al detectar el error, muestra un mensaje de alerta e impide continuar hasta corregirlo
- Control Correctivo:
 - Un programa que detecta el ruido en comunicaciones y permite corregir datos corruptos
 - Ejemplos:
 - Algoritmos de detección y corrección de errores en comunicaciones (códigos CRC, Hamming):
 - El receptor identifica “ruido” en el paquete de datos y repara los bits dañados automáticamente

- Mecanismos de rollback en bases de datos: al fallar una transacción, se devuelve el sistema al estado anterior consistente

10. *¿Cuál es la tarea del auditor en cuanto a los controles?*

EL objetivo de la auditoría es reducir las pérdidas esperadas por eventos ilegales mediante:

- Controles preventivos: reducen la probabilidad de que estos eventos ocurran
- Controles detectivos y correctivos: reducen la cantidad de pérdidas cuando los eventos ilegales ocurren

La tarea del auditor es determinar si los controles están ubicados y funcionan para prevenir los eventos ilegales

11. *Explique desde el punto de vista de auditoría de sistemas de información el concepto de “factorizar en subsistemas” y qué criterio(s) se aplica(n) para factorizar un sistema en subsistemas.*

Para administrar la complejidad, se sugiere factorizar el sistema en subsistemas. El primer paso para comprender un sistema complejo es particionarlo en subsistemas

Un subsistema es un componente lógico de un sistema que:

- Realiza ciertas funciones básicas necesarias para el sistema en general
- Le permite atender sus objetivos fundamentales

Para poder factorizar, se necesita un criterio: la esencia de un subsistema es la función que realiza

Los auditores deben identificar primero, las principales funciones que el sistema realiza para cumplir sus objetivos

El proceso de factorización termina cuando se ha particionado el sistema en partes lo suficientemente pequeñas, de tal modo que puedan ser entendidas y evaluadas

Hay dos formas de factorización por funciones:

- Funciones gerenciales: las funciones que se deben realizar para asegurar que el desarrollo, la implementación, operación y mantenimiento de los sistemas de información proceden de una forma planificada y controlada
- Funciones de aplicación: tareas que son necesarias ejecutar para realizar un procesamiento de información confiable. Relacionado con “ciclos”

12. *Indique qué otros criterios de factorización existen.*

Además de la factorización por funciones, existen otras dos guías:

- Acoplamiento:
 - Cada subsistema debería ser relativamente independiente de otros subsistemas

- Sistemas con poco acoplamiento son más fáciles de comprender
- Cohesión:
 - Cada subsistema debe ser internamente cohesivo
 - Todas las actividades realizadas por el sistema apuntan a cumplir la función principal del subsistema

13. ¿De qué manera se mide la confiabilidad de los controles?

Para evaluar la confiabilidad de los controles:

1. Se deben identificar todos los posibles tipos de eventos que pueden ocurrir en el subsistema
2. Se deben considerar todos los eventos válidos o ilegales

Para identificar los eventos, hay que considerar las principales funciones que realiza el subsistema. Para cada función:

1. Analizar cómo debería realizarse
2. Evaluar cómo el subsistema cumple con esa visión normativa

Para determinar si un evento es legal o ilegal se deben considerar las transacciones que pueden ocurrir como input al subsistema

Todos los eventos en un sistema de aplicación deben surgir de una transacción

Los auditores deben recolectar evidencias sobre la existencia y confiabilidad de los controles, para determinar si las pérdidas por los eventos ilegales se reducen a niveles aceptables

Para cada evento ilegal, se debe considerar:

1. Cómo los controles cubren a ese tipo de evento
2. Cuán confiables son los controles
3. Si puede ocurrir un error material o una irregularidad

14. Identifique cuatro tipos de riesgos. Explique la naturaleza de cada uno de ellos.

Los 4 tipos de riesgos son:

1. Riesgo deseado:
 - El riesgo que se desea correr
 - Primero los auditores eligen el nivel de RDA
 - Evalúan las consecuencias de fracasar en detectar las pérdidas materiales reales o potenciales
2. Riesgo inherente:
 - Refleja la probabilidad que una pérdida material o una imputación errónea exista en algún segmento de la auditoría, antes de que sea considerada la confiabilidad de los controles internos
 - Los auditores consideran factores generales tales como:
 - La naturaleza de la organización (la posición en el mercado)
 - La industria en la que opera (¿la industria está sujeta a cambios rápidos?)

- Las características del gerenciamiento (¿es agresivo y autocrático?)
 - Intereses contables y de auditoría (¿se usan técnicas?)
- Se consideran luego los RI asociados con diferentes segmentos de la auditoría (ciclos, sistemas de aplicación, ...)
- Para cada segmento, se consideran factores tales como:
 - Sistemas financieros:
 - Proveen controles financieros sobre los principales activos de la organización
 - Poseen alto RI
 - Son el blanco de acciones delictivas y fraudes
 - Ejemplo: sistema de facturación
 - Sistemas estratégicos:
 - Proveen ventajas competitivas para la organización
 - Comprometen clientes, proveedores, secretos de marca
 - Tienen alto RI
 - Son blanco de espionaje industrial, o acciones indebidas de la competencia
 - Ejemplo: el sistema que soporta la operatoria comercial de una empresa
 - Sistemas de operación crítica:
 - Aquellos sistemas que pueden paralizar a la organización si fallan
 - Generalmente tienen alto RI
 - Ejemplo: sistemas de control de producción, sistemas de reservas
 - Sistemas de tecnología avanzada:
 - Sistemas que usan tecnología de punta
 - Tienen alto RI, debido a la falta de experiencia en ese tipo de sistemas

3. Riesgo de control:

- Refleja la probabilidad que en algún segmento de la auditoría, los controles internos no prevengan, detecten o corrijan pérdidas materiales o imputaciones erróneas que puedan surgir
- Para evaluar el nivel de RC asociado con cada segmento de la auditoría, se debe considerar la confiabilidad de los controles gerenciales y de aplicación
- Generalmente, se identifican y evalúan primero los controles en los subsistemas gerenciales
- Los controles gerenciales actúan como capas de cebolla protectivas, por encima de los controles de aplicación
- El buen nivel de los controles externos garantizan el nivel de los controles internos
- Los controles gerenciales se evalúan en general, y no para cada aplicación

4. Riesgo de detección:
 - Refleja la probabilidad que los procedimientos de auditoría utilizados en algún segmento, fallen en detectar pérdidas materiales o imputaciones erróneas
 - Finalmente, se calcula el nivel de RD que se debe lograr para cumplir con el RDA
 - Se diseñan procedimientos de recolección de evidencia para intentar lograr el nivel de RD
 - En general:
 - Los auditores no recolectan la cantidad de evidencia que ellos desearían
 - Deben ser astutos para determinar en dónde aplicar los procedimientos de auditoría, y cómo interpretar la evidencia recolectada

Parte III - Proceso de Auditoría

15. Explique brevemente el proceso de auditoría.

1. Planificación: definir alcance, objetivos, equipo, obtener información del cliente y realizar revisiones analíticas preliminares para identificar áreas de riesgo
2. Comprensión de controles: usar cuestionarios, inspecciones y observaciones para verificar el diseño y existencia de los controles internos
3. Evaluación de riesgo de control: estimar si los controles son suficientes para mitigar riesgos; decidir hasta qué punto fiarse de ellos
4. Si se confía en los controles:
 - a. Testeo de controles (si procede): reprocesos, inspecciones u observaciones para comprobar que los controles gerenciales y de aplicación operan efectivamente
 - b. Reevaluación del riesgo de control
 - c. ¿Aún se confía en los controles?
 - i. Sí → ¿Aumenta la confianza en los controles?
 1. Sí → Volver a 4.
 2. No → Testeo sustantivo limitado
 - ii. No → Testeo sustantivo extendido
5. Testeo sustantivo:
 - a. Detalle de transacciones: revisar facturación, cálculos y registros de entradas para detectar errores o fraudes
 - b. Detalle de balances: confirmar saldos vía confirmaciones externas (circularización) o comprobación documental
6. Conclusión y cierre: recopilar evidencia final, reevaluar riesgos, asegurar cobertura adecuada de objetivos
7. Informe: redactar y presentar hallazgos, conclusiones y recomendaciones

16. Enuncie cinco tipos de procedimientos de auditoría que pueden ser usados para recolectar evidencia en una auditoría.

A fin de recolectar evidencia, para determinar si ocurrieron pérdidas materiales o la información financiera es errónea, se usan los siguientes procedimientos:

1. Procedimientos para comprender los controles
2. Testeo de controles
3. Testeos substantivos de detalle de transacciones
4. Testeos substantivos de detalle de balances contables
5. Procedimientos de revisión analítica

Existen distintas técnicas para recolectar evidencia:

1. Revisión de papeles de trabajo de auditorías previas
2. Entrevistas con alta gerencia y personal superior
3. Observación de cómo se desarrollan las actividades
4. Revisión de documentación de sistemas

17. Enumere tres tipos de testeos que se pueden realizar durante una auditoría.

1. Testeo de controles: evalúa la eficacia operativa de controles internos
2. Testeos substantivos de detalle de transacciones: examina cada operación (facturas, órdenes) en busca de errores monetarios o irregularidades
3. Testeos substantivos de detalle de balances (o resultados generales): verifica los saldos finales (cuentas por cobrar, inventarios) y cuantifica posibles pérdidas

18. ¿Cómo se lleva a cabo la planificación de una auditoría? Cite diferencias entre auditoría interna y externa.

Las tareas de planificación de una auditoría son:

1. Determinar el alcance de la auditoría: determinar qué se va a auditar
2. Emitir una opinión sobre el RDA
3. Emitir una opinión sobre el RI:
 - El RI depende del segmento a auditar
 - Algunos segmentos son más susceptibles a errores, irregularidades, ineficiencias, o ineficacias
 - Para cada segmento evaluar los factores que conducen a RI, por ejemplo:
 - Sistema con manejo de efectivo: posibilidades de defraudaciones
 - Sistema complejo tecnológicamente: posibilidades de mal uso de recursos
4. Emitir una opinión sobre el RC:
 - Para esto, los auditores deben comprender los controles internos usados dentro de la organización
 - Los controles internos (CI) comprenden 5 componentes relacionados:
 - Controles de entorno
 - Evaluación de riesgo
 - Actividades de control
 - Información y comunicación
 - Monitoreo

5. Calcular el RD que se debe lograr para cumplir con el RDA
6. Recolectar evidencia:
 - Existen distintas técnicas para recolectar evidencia:
 - Revisión de papeles de trabajo de auditorías previas
 - Entrevistas con alta gerencia y personal superior
 - Observación de cómo se desarrollan las actividades
 - Revisión de documentación de sistemas
7. Documentar evidencia:
 - La evidencia se documenta:
 - Completando cuestionarios
 - Construyendo diagramas de flujo de alto nivel
 - Construyendo tablas de decisión
 - Redactando descripciones narrativas
 - Utilizando herramientas CASE

19. Describa el contenido de un informe de auditoría.

Un informe típico debería incluir:

- Una introducción que describa los objetivos de la auditoría
- El enfoque general utilizado
- Un resumen de las conclusiones críticas
- Recomendaciones para abordar las conclusiones críticas
- Datos que respalden las conclusiones críticas

20. Describa los cuatro tipos de opinión que un auditor puede emitir

Los estándares en varios países requieren que la opinión sea:

1. Opinión excusada: en base al trabajo realizado no se puede emitir opinión
2. Opinión adversa: se concluye que han ocurrido pérdidas materiales o que los estados financieros están distorsionados
3. Opinión con calificación: se concluye que han ocurrido pérdidas materiales o existen registros incorrectos, pero las cantidades no son considerables
4. Opinión sin calificación: el auditor considera que no han ocurrido pérdidas materiales o no existen registros incorrectos

Parte IV - Gobernanza de TI

21. Explique el significado del concepto “Gobernanza de TI”.

La Gobernanza de TI es un subconjunto de Gobierno Corporativo de las organizaciones que se centra en los sistemas de TI, su desempeño y los riesgos asociados

Gobernanza de TI:

- Trata con la relación entre el enfoque empresarial y la gestión de TI
- Destaca la importancia de las cuestiones de TI
- Promueve que las decisiones estratégicas de TI deben ser tomadas por una junta directiva corporativa

Metas:

- Asegurar que las inversiones en TI generen valor
- Mitigar riesgos asociados con TI
- Establecer quién toma las decisiones (privilegios, presupuestos, prioridades) y quién rinde cuentas por ellas

22. Explique qué es COBIT y cuáles son sus elementos.

COBIT (Control Objectives for Information and Related Technologies) es un marco de referencia para la gobernanza y gestión de TI a nivel empresarial. Sus elementos clave son:

- Procesos de TI y dominios: mapeo de actividades en procesos de gobernanza (EDM) y administración (APO, BAI, DSS, MEA)
- Objetivos de control: resultados deseados a nivel de cada proceso (alto nivel) y desglosados en controles detallados
- Prácticas de control: el “cómo” y “por qué” implementar cada objetivo de control en detalle
- Guías de auditoría: orientaciones para evaluar el cumplimiento de controles (qué preguntar, cómo evidenciar)
- Guías de administración: modelos de madurez (MMs), factores críticos de éxito (CSFs), indicadores de metas (KGIs) y de desempeño (KPIs)

23. Explique la diferencia entre Gobernanza y Administración de TI.

Administración de TI: se trata de tomar e implementar decisiones de TI

Gobernanza de TI: se trata de quién toma las decisiones de TI:

- Quién tiene autoridad para tomar las decisiones importantes
- Quién tiene información para tomar las decisiones importantes
- Quién es responsable por implementar las decisiones importantes

24. ¿Cuáles son los principios de COBIT?

Los principios de COBIT son:

1. Satisfacer las necesidades de las partes interesadas:
 - Garantizar que las empresas aporten valor a sus partes interesadas mediante la obtención de beneficios, la optimización del uso de los recursos y la gestión de riesgos
 - Convertir requerimientos de negocio en objetivos de TI
2. Cubrir la empresa de extremo a extremo:
 - Tener en cuenta todos los sistemas de gobernanza y administración relacionados con TI para que sean integrales y de extremo a extremo (incluyendo tanto sistemas internos como externos)
 - Gobernar y gestionar todos los recursos de TI, internos y externos
3. Aplicar un marco integrado: alinearse con otros estándares y buenas prácticas relacionadas con TI, sirviendo de marco general para la gobernanza y administración de TI empresarial
4. Habilitar un enfoque holístico:

- Tener en cuenta los elementos que interactúan, especificar un conjunto de habilitadores para definir un sistema integral de gobernanza y administración de TI empresarial
 - Definir “habilitadores” (procesos, estructuras, personas, información...) que interactúan para lograr la gobernanza
5. Separar las funciones principales: establecer una distinción clara entre las funciones de gobernanza y administración

25. Indique de qué forma organiza COBIT los procesos de TI.

COBIT estructura los procesos en dos grandes dominios:

1. Gobernanza (5 procesos EDM):
 - Evaluate (evaluar necesidades y riesgos)
 - Direct (definir estrategias y prioridades)
 - Monitor (supervisar desempeño y cumplimiento)
2. Administración (32 procesos, agrupados en 4 dominios):
 - APO: Alinear, Planear y Organizar
 - BAI: Construir, Adquirir e Implementar
 - DSS: Entrega, Servicio y Soporte
 - MEA: Monitorear y Evaluar

26. Explique cómo COBIT clasifica la administración de TI.

En cuatro dominios que describen fases del ciclo de vida de los servicios y soluciones:

1. APO (Align, Plan and Organize):
 - Establecer estrategia, arquitectura y gobierno operativo
 - Abarca estrategias y tácticas y se interesa en la forma que TI puede contribuir a alcanzar los objetivos de negocio
 - APO se interesa en:
 - La comprensión de la visión a planificar, comunicar y gestionar
 - Una organización e infraestructura adecuadas para su puesta en marcha
2. BAI (Build, Acquire and Implement):
 - Desarrollar o adquirir y desplegar nuevas capacidades
 - Abarca soluciones de TI que necesitan ser identificadas, desarrolladas o adquiridas, implementadas e integradas en el proceso de negocio
 - BAI se enfoca en:
 - Los cambios en las soluciones de TI existentes
 - El mantenimiento de sistemas existentes
 - Asegurar que las soluciones continúan cumpliendo con las metas empresariales
3. DSS (Deliver, Service and Support):
 - Gestionar operaciones diarias, seguridad y continuidad
 - Trata sobre la entrega efectiva de los servicios requeridos, incluyendo operaciones, seguridad y capacitaciones de continuidad

- DSS se enfoca en:
 - La gestión de seguridad y continuidad del servicio
 - El soporte de servicios para usuarios
 - La administración de datos
 - Instalaciones operacionales
- 4. MEA (Monitor, Evaluate and Assess):
 - Medir el desempeño, controlar el cumplimiento y mejorar procesos
 - Trata de la evaluación regular de los procesos de TI para controlar su calidad y el cumplimiento de los requisitos de control
 - MEA se enfoca en:
 - La gestión de desempeño
 - El cumplimiento normativo
 - El control interno

27. Justifique la importancia de aplicar COBIT en una organización

Beneficios de aplicar COBIT:

- Permite a los administradores públicos cerrar la brecha entre los requisitos de control, los problemas técnicos y los riesgos comerciales
- Permite un desarrollo claro de políticas y buenas prácticas para el control de TI en todas las organizaciones gubernamentales
- Enfatiza el cumplimiento regulatorio
- Ayuda a las organizaciones del sector público a aumentar el valor obtenido de TI
- Permite la alineación y simplifica la implementación de la gobernanza de TI en el sector público
- Ayuda a los gobiernos a proporcionar servicios mejores y más personalizados a los ciudadanos y las empresas
- Optimiza las inversiones en TI, garantiza una prestación de servicios efectiva y proporciona medidas

Importancia:

- Alinea TI con el negocio: traduce expectativas de las partes interesadas en objetivos claros y medibles
- Gestión de riesgos: identifica y mitiga riesgos de TI antes de que impacten en los resultados
- Optimización de recursos: promueve un uso eficiente de personas, infraestructura y presupuestos
- Marco integrado: se fundamenta en mejores prácticas y se integra con otros estándares, evitando silos
- Medición y mejora continua: con KPIs y modelos de madurez, facilita el seguimiento y la evolución sistemática
- Soporte a la auditoría: sus guías y objetivos de control sirven de referencia para evaluar la eficacia de los controles internos de TI